

Модель угроз для системы СУПД

(Система управления правами доступа и учётными записями)

Версия 1.0 от 05 декабря 2025 г.

1. Введение

Настоящий документ описывает модель угроз для системы СУПД, разработанной на основе open-source компонентов для управления идентичностями, ролями и доступами (IGA/IDM). Модель угроз построена по методологии STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege), рекомендованной Microsoft для анализа рисков безопасности.

Цель — выявить потенциальные угрозы, оценить их влияние и предложить меры минимизации. Анализ основан на архитектуре системы, описанной в документе “Архитектура системы СУПД”.

1.1. Область применения

- Пользователи: >1000 сотрудников + подрядчики.
- Компоненты: Traefik, Authentik, React Portal, Temporal.io, midPoint, PostgreSQL, MinIO.
- Интеграции: 27 целевых систем (SCIM, REST, LDAP).
- Стандарты: ISO 27001, GDPR, ФЗ-152, ФСТЭК.

1.2. Предположения

- Система развернута в Kubernetes/Docker с TLS 1.3 и MFA.
- Внешний периметр защищен WAF/Firewall.
- Угрозы от внутренних пользователей (инсайдеры) учитываются.

2. Обзор архитектуры (кратко)

Система включает:

- Фронтенд: React PWA + Authentik (SSO/MFA).
- Бэкенд: Temporal (workflow) + midPoint (IGA core, SoD, provisioning).
- Хранилище: PostgreSQL + MinIO.
- Ingress: Traefik.
- Целевые системы: Интеграции через коннекторы.

Потоки: Аутентификация → Запросы/Workflow → Provisioning → Аудит.

3. Модель угроз по STRIDE

Каждую категорию угроз анализируем по компонентам системы, оцениваем вероятность (Низкая/Средняя/Высокая), влияние (Низкое/Среднее/Высокое) и предлагаем минимизацию.

3.1. Spoofing (Подмена идентичности)

Угрозы, связанные с фальсификацией идентификаторов.

Компонент	Угроза	Вероятность	Влияние	Митиг
-----------	--------	-------------	---------	-------

Authentik	Подмена пользователя через слабый MFA или кражу сессии (session hijacking).	Средняя	Высокое	Обязател MFA (TOTP/We короткий токенов, мониторинг аномалий
React Portal	CSRF/XSS-атаки для подмены запросов от лица пользователя.	Средняя	Высокое	CSP, X-Fr Options, s cookies, C ZAP тестиров
midPoint	Подмена в API (например, через поддельный OIDC-токен).	Низкая	Высокое	Валидаци RBAC в п аудит все вызовов.
Целевые системы	Подмена в коннекторах (например, MITM в REST/SCIM).	Средняя	Высокое	TLS mutu OAuth2 д интеграц ротация и

3.2. Tampering (Манипуляция данными)

Угрозы изменения данных в покое или транзите.

Компонент	Угроза	Вероятность	Влияние	Митиги
PostgreSQL	Манипуляция справочника пользователей/ролей (SQL injection).	Низкая	Высокое	Prepared statements шифров данных в покое (pgcrypt доступ только ч midPoint)
Temporal	Изменение workflow (например, подмена этапов согласования).	Средняя	Высокое	Immutable workflow цифровые подписи шагах, с изменен
midPoint	Tampering матрицы ролей или SoD-реестра.	Средняя	Высокое	Хэширо: объекто version control в репозит midPoint
Интеграции	Перехват и изменение provisioning-команд (например, в LDAP).	Средняя	Высокое	Шифрове транзит (TLS), integrity checks в коннект

3.3. Repudiation (Отказ от действий)

Угрозы, когда действия не могут быть доказаны.

Компонент	Угроза	Вероятность	Влияние
-----------	--------	-------------	---------

React Portal	Пользователь отрицает подачу заявки.	Низкая	Среднее	1
Temporal	Отказ от согласования в workflow.	Средняя	Среднее	1
midPoint	Отказ от provisioning (например, “я не назначал роль”).	Низкая	Высокое	1
Общий	Инсайдер отрицает несанкционированный доступ.	Средняя	Высокое	1

3.4. Information Disclosure (Раскрытие информации)

Угрозы утечки конфиденциальных данных.

Компонент	Угроза	Вероятность	Влияние	Митинг
PostgreSQL	Утечка справочника сотрудников (data breach).	Средняя	Высокое	Шифрование, доступ по ролям (RBAC), D-мониторинг
Traefik	Прослушка трафика (MITM).	Низкая	Высокое	TLS 1.3 everywhere, HSTS, certificate pinning.
React Portal	Утечка через API (например, overfetching данных).	Средняя	Высокое	GraphQL с ограничением token score, аудит запросов
Целевые системы	Утечка credentials в коннекторах.	Средняя	Высокое	Vault для хранения секретов, ротация ключей, минимальные привилегии

3.5. Denial of Service (Отказ в обслуживании)

Угрозы, приводящие к недоступности.

Компонент	Угроза	Вероятность	Влияние	Митинг
Traefik	DDoS на ingress.	Высокая	Высокое	Rate limit, WAF, autoscaling

				Kubernetes
Temporal	Перегрузка workflow (массовые заявки).	Средняя	Среднее	Quotas на API, circuit breakers.
midPoint	DoS на provisioning (например, loop в коннекторах).	Низкая	Высокое	Resource limits в Docker, мониторинг (Prometheus)
PostgreSQL	Query flood (замедление БД).	Средняя	Высокое	Indexes, query optimization, connection pooling.

3.6. Elevation of Privilege (Повышение привилегий)

Угрозы несанкционированного доступа к повышенным правам.

Компонент	Угроза	Вероятность	Влияние	Митигация
Authentik	Escalation через уязвимость в MFA.	Низкая	Высокое	Least privilege, регулярное обновление, penetration testing.
midPoint	Получение admin-ролей через SoD-байпас.	Средняя	Высокое	Автоматическая проверка (>10 конфликтов), birthright, только на основе логики
Temporal	Escalation в workflow (подмена согласующего).	Средняя	Высокое	Delegation, аудитом эскалации только на основе иерархии
Общий	Инсайдер эскалирует через legacy-интеграцию.	Высокая	Высокое	Zero-trust для администраторов, ежеквартальный аудит д

4. Общая оценка рисков

- Высокие риски: Spoofing и Elevation (из-за человеческого фактора).
 - Средние: Tampering и Disclosure (защищены криптографией).
 - Низкие: Repudiation (сильный аудит).
- Общий уровень: Средний, при условии реализации митингаций.

5. Рекомендации по минимизации

- Регулярное тестирование: Penetration testing (OWASP ZAP), нагрузочное.
- Мониторинг: SIEM для логов, alerting на аномалии.
- Обновления: Автоматический CI/CD с GitHub Actions/Terraform.
- Соответствие: Аудит на GDPR/ФЗ-152 ежеквартально.

6. Вывод

Модель угроз STRIDE охватывает ключевые риски СУПД.
Рекомендуется интегрировать в SDLC и пересматривать ежегодно.

На основе модели STRIDE и архитектуры системы (midPoint + Authentik + Temporal + React PWA + Traefik) проведена оценка рисков по методологии DREAD (Microsoft). Шкала оценки: 1-3 (1 = низкий, 2 = средний, 3 = высокий) Итоговый риск = $(D + R + E + A + D) / 5$

2,4-3,0 → Высокий 1,8-2,39 → Средний $\leq 1,79$ → Низкий

№	Угроза (STRIDE)	Потенциальный ущерб (Damage Potential)	Воспроизводимость (Reproducibility)
1	Компрометация Authentik (кража сессии, обход MFA)	3 (полный контроль над доступами >1000 сотрудников)	2 (требуется валидная сессия или утечка токена)
2	Подмена пользователя в React Portal (XSS/CSRF)	3 (создание заявок от чужого имени)	3 (воспроизводимо при найденной XSS)
3	SQL-инъекция / утечка БД PostgreSQL	3 (утечка всего справочника сотрудников + история доступов)	2 (требуется доступ к midPoint API)
4	Компрометация учётной записи администратора midPoint	3 (полный контроль над всеми ролями и SoD)	2 (требуется доступ)
5	DDoS на Traefik / исчерпание ресурсов	2 (временная недоступность self-service)	3 (легко воспроизводимо)
6	Обход SoD (назначение конфликтующих ролей)	3 (нарушение сегрегации обязанностей)	1 (блокируется автоматически)
7	Перехват provisioning-трафика (MITM в LDAP/SCIM)	3 (подмена команд в целевые системы)	1 (TLS 1.3 + mTLS)
8	Инсайдер создаёт скрытую backdoor-роль	3 (полный контроль)	2 (если есть доступ к midPoint admin)
	Утечка секретов	3 (полный доступ)	

9	секретов коннекторов (пароли 1C/SAP)	3 (полный доступ к системам)	2 (требуется доступ)	
10	Массовый отзыв доступов через сбой workflow (Temporal)	2 (временный хаос доступов)	1 (требуется доступ к Temporal admin)	

Итоговая приоритизация рисков (топ-6)

Ранг	Угроза	Итоговый риск DREAD	Уровень
1	DDoS на Traefik	2,8	Высокий
2	XSS/CSRF в React Portal	2,6	Высокий
3-6	Компрометация Authentik / midPoint admin / утечка секретов / инсайдер-backdoor	2,4	Высокий

Рекомендуемый план снижения рисков (2026 г.)

Мероприятие	Срок	Ответственный	Ожидаемый эффект
Внедрение WebAuthn + YubiKey для всех администраторов и ИБ	Q1 2026	ИБ + ИТ	Снижение риска №1,4
Подключение WAF + rate-limiting + GeoIP-блокировка	Январь 2026	ИТ-инфраструктура	Снижение риска №5
Автоматический OWASP ZAP + Nuclei в CI/CD	Февраль 2026	DevOps	Снижение риска №2
Перевод всех коннекторов на HashiCorp Vault + mTLS	Март 2026	ИТ-интеграции	Снижение рисков №7,9
Внедрение двойного согласования на создание/изменение ролей	Q2 2026	ИБ + midPoint admin	Снижение риска №8
Ежеквартальный penetration test + red team	Постоянно	Внешний подрядчик	Общая верификация системы

На основе модели DREAD (Damage Potential, Reproducibility, Exploitability, Affected Users, Discoverability), представленной в документе “Модель угроз DREAD для рисков”, проводится расширенный анализ топ-рисков с оценкой $\geq 2,4$. Анализ включает

детальные сценарии угроз, потенциальные последствия, расширенные стратегии минимизации на основе лучших практик 2025 года. Топ-риски:

DDoS на Traefik (2,8) XSS/CSRF в React Portal (2,6) Компрометация Authentik (2,4) Компрометация midPoint admin (2,4) Утечка секретов в коннекторах (2,4) Инсайдер-backdoor в RBAC (2,4)

Анализ учитывает актуальные рекомендации OWASP, K8s Security и другие источники для минимизации рисков в open-source IGA-системах.

Риск 1: DDoS на Traefik (2,8)

Сценарий угрозы Злоумышленник (внешний или инсайдер) инициирует распределённую атаку на ingress-контроллер Traefik, используя ботнеты для генерации L7-запросов (например, HTTP flood на /api или self-service портал). Это может привести к исчерпанию ресурсов (CPU/RAM) в Kubernetes, особенно если не настроены лимиты. Воспроизводимость высока, так как Traefik экспонирован внешне, а эксплуатация проста с использованием инструментов вроде LOIC или cloud-based DDoS-сервисов. Обнаруживается по метрикам (Prometheus), но без WAF может быть поздно. Потенциальные последствия

Недоступность self-service портала (>1000 пользователей не смогут подавать заявки на доступы). Задержки в workflow (Temporal) и provisioning (midPoint), приводящие к срыву SLA (≤24 ч для birthright). Финансовые потери: downtime в критических системах (SAP/1C), репутационные риски по Ф3-152. Масштаб: все 1000+ пользователей + 27 целевых систем.

Расширенные стратегии минимизации

Использование защиты облачного провайдера: Внедрить встроенные DDoS-митингаии от AWS/GCP/Azure, такие как AWS Shield или Google Cloud Armor, для поглощения трафика на L3/L4. Это снижает нагрузку на Traefik. Rate-limiting на ingress: Настроить аннотации Traefik для ограничения запросов (например, 100 req/min на IP), комбинируя с connection limits для предотвращения простых DDoS. WAF и GeoIP-фильтрация: Интегрировать ModSecurity или Traefik Middleware для блокировки подозрительного трафика; добавить GeoIP для ограничения доступа только из РФ/корпоративных сетей. Autoscaling и circuit breakers: В Kubernetes настроить HPA (Horizontal Pod Autoscaler) для Traefik и backend-сервисов; использовать Istio/Envoy для circuit breaking. Мониторинг: Интегрировать с ELK/Prometheus для алертов на аномалии (спайки трафика).

DREAD пересчёт после митингаий: 2,0 (Средний).

Риск 2: XSS/CSRF в React Portal (2,6)

Сценарий угрозы Злоумышленник внедряет вредоносный скрипт через уязвимости в React (например, dynamic rendering пользовательского ввода в заявках) или CSRF-токены, подменяя действия (создание/отзыв доступов). Воспроизводимо при эксплуатации известных уязвимостей (OWASP Top 10), лёгкость высока для веб-атак. Затрагивает всех пользователей портала; обнаруживается по логам, но постфактум. Потенциальные последствия

Несанкционированное назначение/отзыв ролей, нарушение SoD. Утечка данных (справочник сотрудников), компрометация compliance (GDPR/Ф3-152). Репутационные потери, штрафы; влияние на 1000+ пользователей.

Расширенные стратегии минимизации

OWASP XSS Prevention: Использовать output encoding (React's dangerouslySetInnerHTML с санитизацией via DOMPurify) и framework protections. CSRF Protection: Внедрить Synchronizer Token Pattern (генерация уникальных токенов на сервере, проверка в заголовках); избегать secret cookies, только POST для мутаций. CSP и SRI: Настроить Content Security Policy (CSP) strict-dynamic, Subresource Integrity для скриптов; X-Frame-Options: DENY. Автоматическое тестирование: Интегрировать OWASP ZAP/Nuclei в CI/CD для сканирования уязвимостей на каждом коммите. Мониторинг: Логировать все запросы с OWASP ModSecurity rules.

DREAD пересчёт: 1,8 (Средний).

Риск 3: Компрометация Authentik (2,4)

Сценарий угрозы Атака на Authentik через MFA fatigue (бомбардировка пуш-уведомлениями) или кражу токенов (session replay). Воспроизводимо через социальную инженерию; лёгкость средняя с инструментами вроде Evilginx. Затрагивает всех; обнаруживается по алертам. Потенциальные последствия

Полный доступ к порталам, манипуляция ролями, утечка РИИ (ФЗ-152 нарушения). Каскадный эффект на 27 систем; юридические риски.

Расширенные стратегии минимизации

Адаптивный MFA: Внедрить risk-based authentication (RBA): повышать уровень MFA по риску (гео, устройство), снижая частоту промптов. FIDO2/Passwordless: Перейти на аппаратные ключи (YubiKey) для админов, минимизируя fatigue. Ограничение попыток: Блокировка после 10 неудач, уведомления о подозрительных входах. Мониторинг токенов: Отслеживать token theft через поведенческий анализ (аномальные IP).

DREAD пересчёт: 1,8 (Средний).

Риск 4: Компрометация midPoint admin (2,4)

Сценарий угрозы Фишинг или слабые пароли приводят к захвату admin-учётки midPoint, позволяя создавать/изменять роли. Воспроизводимо; лёгкость средняя. Затрагивает всю систему. Потенциальные последствия

Нарушение RBAC/SoD, несанкционированный доступ к 27 системам. Compliance-штрафы (SOX/GDPR).

Расширенные стратегии минимизации

PIM/PAM: Внедрить Privileged Identity Management: временный доступ, just-in-time elevation. MFA и Password Policy: Строгие политики (min 16 символов, ротация), MFA всегда. Сегрегация: Отдельные учётки для серверов/воркстейшн, ограничение сетевого доступа. Автоматизация: Workflow для изменений, аудит.

DREAD пересчёт: 1,8 (Средний).

Риск 5: Утечка секретов в коннекторах (2,4)

Сценарий угрозы Утечка credentials (API-ключи для 1C/SAP) через misconfig в Kubernetes secrets или logs. Воспроизводимо при скане репозитория; лёгкость средняя. Потенциальные последствия

Доступ к целевым системам, data breach. Каскадные утечки РИИ.

Расширенные стратегии минимизации

Централизованное управление: Использовать HashiCorp Vault для динамических секретов, инъекция в pods. Encryption at Rest: Включить K8s EncryptionConfig для secrets. Vault Secrets Operator: Определение секретов в Git без значений, автоматическая ротация. Сканирование: Trivy/Snyk в CI/CD для выявления утечек.

DREAD пересчёт: 1,8 (Средний).

Риск 6: Инсайдер-backdoor в RBAC (2,4)

Сценарий угрозы Инсайдер (admin) создаёт скрытую роль с elevated privileges, байпасс SoD. Воспроизводимо; обнаружение трудно без аудита. Потенциальные последствия

Долгосрочный несанкционированный доступ, утечки. Нарушение compliance.

Расширенные стратегии минимизации

Детекция: Мониторинг аномалий (UEBA), аудит изменений ролей. Профилактика: Двойное одобрение изменений, least privilege. IDS для инсайдеров: Блокировка неавторизованных доступов.

DREAD пересчёт: 1,8 (Средний).

Заключение

Расширенный анализ снижает общий уровень рисков до Среднего. Рекомендуется внедрение в 2026 г.

Утверждаю:

Директор по информационной безопасности

_____/ ФИО /

«05» декабря 2025 г.